

Эскалация привилегий

Shatter Attack

Автор: [Твоё имя]

Группа: [Твоя группа]

Дата: [Дата]

SYSTEM ERROR

Privilege boundary broken

low → high
message injection

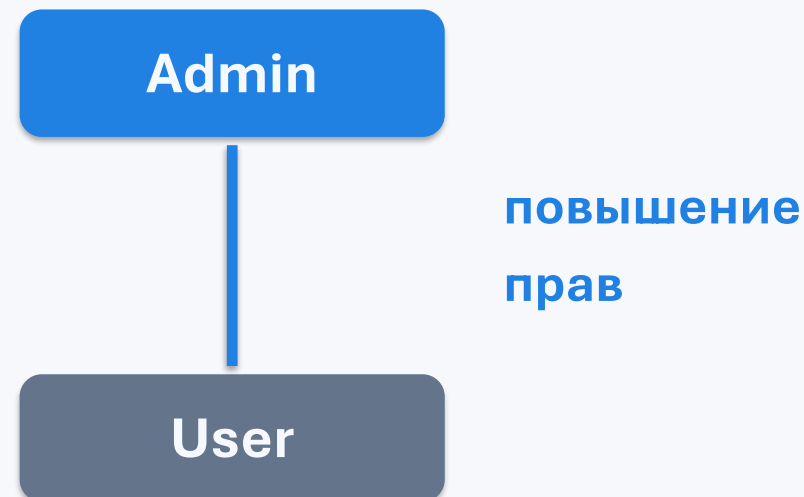
ACCESS?

Что такое эскалация привилегий?

Эскалация привилегий — получение злоумышленником прав, превышающих его текущие.

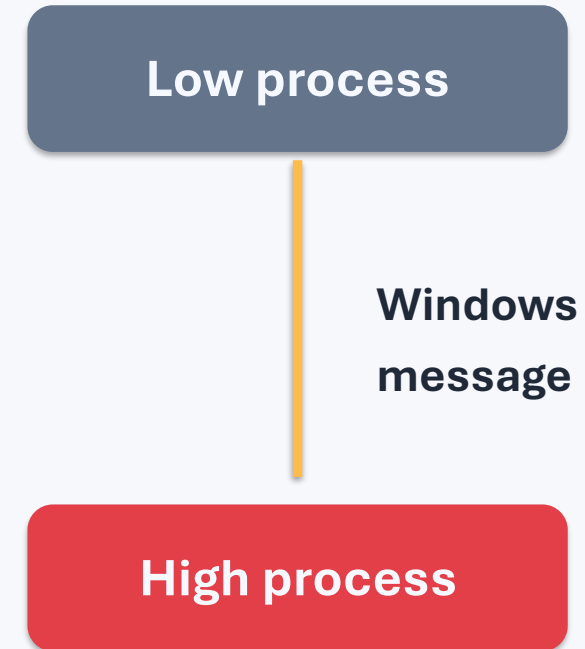
Vertical (вертикальная) — от обычного пользователя к администратору или root.

Horizontal (горизонтальная) — доступ к другому пользователю того же уровня.



Shatter Attack — что это?

- Атака на операционные системы семейства Windows.
- Впервые описана в 2002 году Крисом Пагетом (Chris Paget).
- Процесс с низкими привилегиями отправляет команды окну процесса с высокими привилегиями.
- Использует механизм обмена сообщениями Windows — Windows Messaging API.



Как работает Windows Messaging

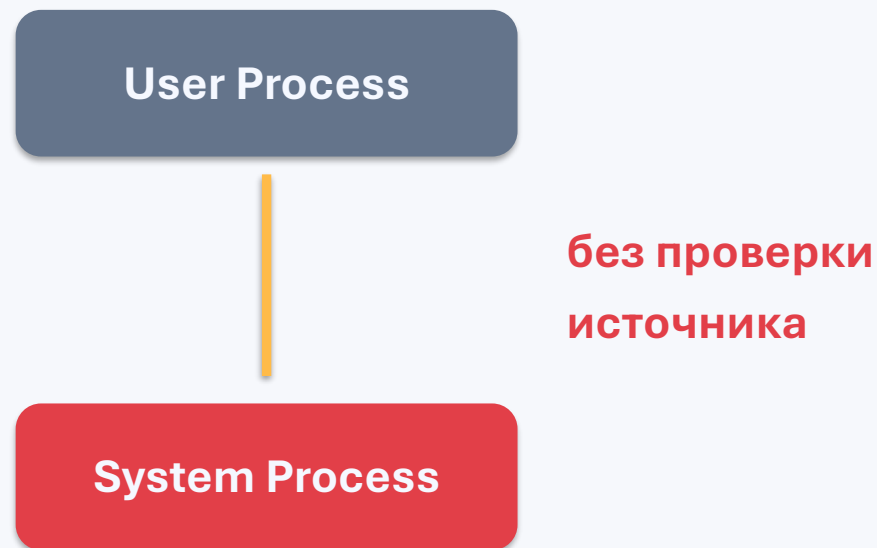
- В Windows GUI работает на основе очереди сообщений — message queue.
- Окна общаются через сообщения: WM_COMMAND, WM_TIMER, WM_USER и др.
- Сообщение содержит HWND, ID сообщения и два параметра: wParam, lParam.



Почему Shatter Attack возможен?

- В Windows XP/2000 и старше сообщения не проверялись на источник.
- Любой процесс мог отправить сообщение любому окну.
- Привилегированный процесс мог выполнить команды из сообщения.
- Низкопривилегированный процесс подставлял вредоносные параметры.

```
SendMessage(hwnd, WM_COMMAND, ID_EXECUTE,  
(LPARAM)"cmd.exe")
```



Пример: запуск командной строки от SYSTEM

- Найти окно процесса с высокими привилегиями, например окно службы.
- Отправить сообщение WM_COMMAND с параметрами на выполнение команды.
- Системный процесс выполняет cmd.exe с правами SYSTEM.

```
HWND hwnd = FindWindow(NULL,  
    "Window of privileged app");  
  
SendMessage(hwnd, WM_COMMAND,  
    ID_EXECUTE,  
    (LPARAM)"cmd.exe");
```

```
C:\Windows\System32> whoami    nt authority\system
```

Что может сделать злоумышленник?

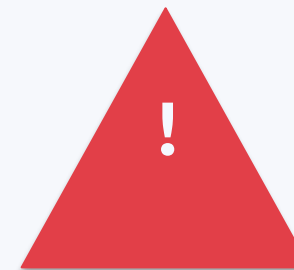
Запустить вредоносный
код с правами SYSTEM

Создать нового
администратора

Отключить антивирус и
системы защиты

Установить бэкдор

Похитить пароли из LSASS



**Итог: полный
контроль над
системой**

Защита от Shatter Attack

- UIPI (User Interface Privilege Isolation) — начиная с Windows Vista.
- Запуск приложений с разными уровнями привилегий в разных сессиях.
- Проверка источника сообщения: IsWindow и проверка PID.
- Микрофильтры сообщений.

Windows версия	Защита
Windows XP/2000	Отсутствует
Windows Vista+	UIPI включена
Windows 10/11	Полная защита

UIPI блокирует низкий →
высокий IL

Актуально ли сейчас?

В современных Windows (Vista/7/8/10/11) атака невозможна в классическом виде из-за UIPI.

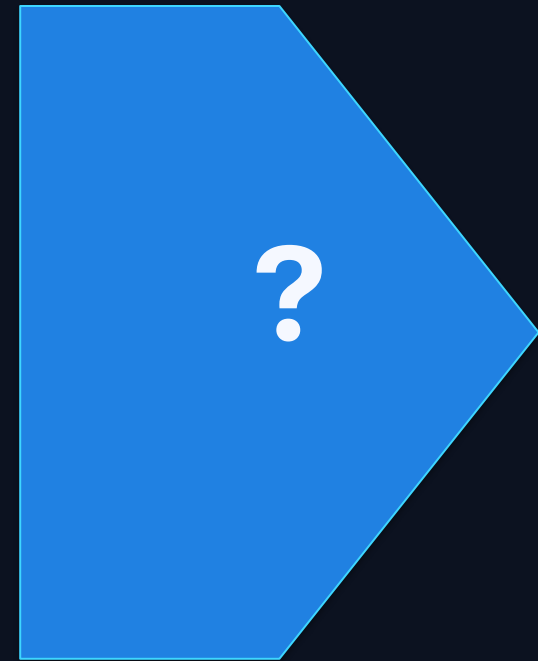
- UIPI блокирует сообщения от процессов с низким уровнем к высокому.
- Атака остаётся актуальной для старых систем XP/2000.
- Также важна для Windows Embedded и изучения истории кибербезопасности.

таймлайн защиты Windows



Выводы

- Shatter Attack — классический пример атаки через легитимные механизмы ОС.
- Атака показала важность проверки источника сообщений.
- Она привела к внедрению UIPI в Windows Vista.
- Главный урок: даже доверенные API могут быть опасны.



Security boundary matters